CLOUD SECURITY — PRACTICAL-BASED LEARNING

PBL 6: Create a Custom IAM Policy for a Cybersecurity Analyst

Standalone report • Anticipated troubleshooting scenarios clearly labeled

1. Aim

Create a dedicated IAM user for a cybersecurity analyst and attach a custom least-privilege policy that provides read-only access to selected AWS security monitoring and audit services, enables MFA and applies an appropriate password policy.

2. Problem Statement

Write a custom IAM policy rather than relying on a prebuilt AWS managed policy. Permit reading CloudTrail, CloudWatch, GuardDuty, AWS Config and Security Hub information, while explicitly preventing EC2 creation/termination, IAM administration, log deletion and changes to monitoring configurations. Test allowed and denied actions.

3. Tools and Services

- AWS IAM users, policies and groups
- IAM policy JSON editor and policy simulator, where available
- Multi-factor authentication (MFA)
- Account-level IAM password policy
- CloudTrail
- CloudWatch
- GuardDuty
- AWS Config
- AWS Security Hub

4. Required Permission Design

Service / area	Required access described by the assignment
CloudTrail	Read event history and trail configuration
CloudWatch	Read metrics, dashboards, alarms and logs
GuardDuty	View findings and detector configuration
AWS Config	View resource configuration and compliance information
Security Hub	View findings and security posture information
EC2	No permission to create or terminate instances
IAM	No permission to modify users, policies, roles or permissions
Audit/monitoring controls	No permission to delete logs, disable trails or change monitoring configuration

5. Procedure

Step 1 — Create a dedicated analyst identity

Create a dedicated IAM user for the cybersecurity analyst, following the lab account's approved identity-management process. Avoid reusing the root identity for routine work.

Step 2 — Create a custom IAM policy

Open IAM Policies and create a policy in JSON. Add the read-only actions required for CloudTrail, CloudWatch, GuardDuty, AWS Config and Security Hub. Add explicit denial statements for the prohibited categories listed in the assignment where appropriate. Use service-specific actions and resource scopes wherever supported; some read actions require wildcard resources.

Step 3 — Validate the policy

Review the policy JSON for valid syntax, correct action names and suitable resource scope. Use the IAM policy editor or policy simulator if available. The exact action list should be checked against current AWS service authorization documentation before attaching the policy.

Step 4 — Attach the policy

Attach the custom policy to the dedicated analyst user or an appropriate group. Confirm that no other attached policy unintentionally grants broader access.

Step 5 — Enable MFA

Configure an MFA device for the analyst identity and verify that it is registered and can be used to authenticate as required by the account's sign-in workflow.

Step 6 — Configure password policy

Set the account-level IAM password policy according to the assignment, including suitable minimum length and password reuse restrictions. Follow the organization's current standard if it is stricter.

Step 7 — Test allowed actions

Sign in as the analyst and verify that the user can read CloudTrail event history and trail configuration, CloudWatch metrics/dashboards/alarms/logs, GuardDuty findings, AWS Config compliance information and Security Hub findings.

Step 8 — Test denied actions

In a controlled lab, attempt an explicitly prohibited operation, such as creating or terminating an EC2 instance or modifying IAM permissions. Confirm that the operation is denied. Do not perform destructive tests against real workloads.

Step 9 — Review audit records

Inspect CloudTrail records for the test actions where available. Record the action, timestamp, identity and allow/deny outcome.

6. Anticipated Errors and Solutions

The following are plausible troubleshooting scenarios, not errors confirmed to have occurred in this user's account.

Error 1 — Invalid JSON syntax

A missing comma, quote or bracket can prevent policy creation. Use the IAM visual/JSON editor validation, check the reported line and revalidate before saving.

Error 2 — Unknown or invalid action name

IAM action names are service-specific and exact. Check the current AWS service authorization reference and correct the action name. Avoid inventing action names.

Error 3 — Policy allows too much or denies required read access

Review attached policies, action scope, resource scope and explicit Deny statements. Explicit Deny overrides Allow. Test the intended read actions and prohibited actions with the policy simulator or a controlled test identity.

Error 4 — Access denied for a read-only page

Some console pages call additional read APIs beyond the main service action. Inspect the denied action in the error or CloudTrail record, confirm that it is necessary for the required read-only task, and add only the minimum authorized permission. Do not respond by attaching AdministratorAccess.

Error 5 — Policy simulator and actual console results differ

The simulator may not fully represent every service, resource policy, permission boundary, session policy, organization SCP or console dependency. Inspect the actual denied action and all applicable policy layers; test with a controlled identity.

Error 6 — MFA setup or sign-in fails

Check that the selected MFA device is supported and registered to the correct user, the device time is synchronized if time-based, and the sign-in flow is using the expected identity. Keep approved recovery options available.

Error 7 — Password policy cannot be changed

Account-level password policy changes may require additional IAM permissions or may be controlled by an organization administrator. Use an authorized administrator and follow organizational policy; do not attempt to bypass account controls.

Error 8 — Prohibited operation unexpectedly succeeds

Check whether another attached user/group policy grants the action, whether the test used the intended identity, and whether the custom policy includes the correct explicit Deny. Review permission boundaries, session policies and organization policies. Stop the test and correct the policy before further use.

Error 9 — CloudTrail event is missing

Confirm the test action actually occurred, search the correct Region and time window, and verify permissions to view the event. Some console actions may trigger a different API event name than expected.

Error 10 — Policy change locks out the analyst

Maintain a separate authorized administrative identity for recovery. Test policy changes with a dedicated lab user before broad rollout, and avoid modifying the only administrative access path.

7. Result and Verification Status

Expected result: the analyst can read the specified security monitoring and audit information, while prohibited EC2 and IAM modifications and changes to audit controls are denied. MFA should be enabled and the account password policy should be configured.

No actual execution evidence was provided for PBL 6 in the available conversation. This report is a planned procedure with anticipated errors and solutions; it does not claim that the IAM user, policy, MFA, password policy or access tests have already been completed.

8. Security Measures

- Use a dedicated analyst identity and least-privilege custom policy.
- Do not grant AdministratorAccess as a workaround for denied reads.
- Enable MFA and apply an appropriate password policy.
- Keep a separate authorized administrator for recovery.
- Restrict policy changes to authorized administrators and review all attached policies.
- Test prohibited operations only in a controlled lab and avoid destructive production actions.
- Use CloudTrail records to audit access tests.

9. Conclusion

This practical develops a custom least-privilege IAM policy for a cybersecurity analyst. The required design grants read access to CloudTrail, CloudWatch, GuardDuty, AWS Config and Security Hub, while preventing resource modification and monitoring-control changes. Completion should be demonstrated with evidence of allowed read operations, denied prohibited actions, MFA configuration and the account password policy. All errors listed here are anticipated examples and should be described as actual errors only if they occur.

10. Screenshots Checklist

- ■ Dedicated analyst IAM user details with sensitive identifiers redacted where appropriate.
- ■ Custom IAM policy JSON and successful validation.
- ■ Policy attachment to the user or group.
- ■ MFA device enabled for the analyst.
- ■ Account-level password policy settings.
- ■ Successful read-only access to CloudTrail Event history.
- ■ Read-only access to CloudWatch, GuardDuty, AWS Config and Security Hub.
- ■ Denied prohibited operation in the controlled lab.
- ■ CloudTrail record of the test action, where available.
- ■ Final review showing no unintended broad policy attachment.